University Security Incident Analysis and Response Improvement Plan

James Summersill | Academic portfolio case study | October 2026

Independent academic analysis of a supplied fictional university scenario. Recommendations were developed as coursework and have not been implemented or tested in a production environment.

Executive assessment

Sandhaven University needs clearer response authority, faster recognition of security incidents, and a practical recovery capability. My analysis connects two supplied incidents to weaknesses in vulnerability governance, detection, escalation, and resilience. I recommend establishing accountable response roles first, then introducing managed monitoring and tested technical controls in phases that fit a four-person IT team.

Scope and method

I reviewed the university profile, policies, and two post-incident summaries; assessed plausible risks; and developed response and governance recommendations. I separated stated evidence from analytical inference and proposed controls. This is a document-based assessment, without access to logs, systems, staff interviews, contracts, or forensic images. The operational sequence below is my proposed design, informed by current NIST incident-response guidance. [1]

Evidence supplied in the scenario

- Four network and systems administrators also perform security monitoring and incident response. The organization intends to establish a dedicated security capability.
- The file-transfer incident describes an outdated MOVEit Transfer deployment, no documented update process, limited edge controls, and approximately 90 days of exploitation. Possible foreign involvement is reported, but attribution is not established.
- The ransomware incident affected all 47 active hosts in one facility segment. Staff isolated that segment; a vendor later identified malware, and leadership paid a ransom. These facts do not establish compromise of the entire university.
- The Registrar has a 90-day request backlog; 20% of records have entered a third-party solution. The scenario does not prove every remaining record is paper-only.

My contribution

The work product is a proposed risk register, response model, two incident playbooks, and a six-month improvement roadmap. Its value is the reasoning and decision structure; no deployment, reduction in incidents, or measured operational improvement is claimed.

Risk assessment and governance

Ratings below are qualitative planning judgments, not calculated probabilities. Likelihood reflects the supplied weaknesses and incident history; impact reflects plausible effects on sensitive records and essential services. High means a credible exposure with substantial business consequences. Validate these judgments through asset discovery, interviews, and control testing. [4]

Risk and evidence	Assessment	Proposed treatment
File-transfer compromise: prior exploitation, weak update governance, limited monitoring.	High likelihood; high impact; priority 1.	Inventory internet-facing services; restrict access; follow vendor remediation; investigate persistence and exposure.
Ransomware: phishing entry and facility-wide host impact in the scenario.	High likelihood; high impact; priority 1.	Improve email and endpoint defenses; test isolation, segmentation, and protected backup restoration.
Account misuse: six-character minimum and infrequent access reviews.	High likelihood; high impact; priority 2.	Deploy MFA; strengthen password controls; automate joiner, mover, and leaver events; review privileged access.
Record disclosure errors: validation difficulties and a request backlog.	Moderate likelihood; high impact; priority 2.	Verify request authority, consent or applicable exception; log required disclosures; test release workflows.

Privacy and vendor governance

FERPA is relevant to the education records described in the scenario. A release workflow should verify the requester, the lawful basis for disclosure, and applicable recordkeeping duties rather than treating every disclosure as requiring consent. [3] Student health records may fall under FERPA rather than HIPAA. Confirm clinic activities, patient populations, covered-entity status, and record classifications before asserting HIPAA duties or hybrid-entity status. [2]

Maintain data classifications, approved storage and transfer methods, retention rules, and vendor ownership. Where HIPAA applies, determine whether a vendor is a business associate before requiring a BAA. Outsourcing payment or record processing does not replace institutional vendor oversight. Legal counsel should determine applicable breach-notification duties from the actual facts.

Proposed incident response playbooks

File transfer exploitation and suspected data theft

- Detect and triage: correlate application, web, identity, database, firewall, and available network-flow records. Investigate unusual account creation, configuration changes, suspicious requests, and unexpected transfers. Establish a timeline; distinguish observed events from suspected exposure.
- Preserve evidence: record timestamps and time zones, export relevant logs, and preserve host evidence with qualified responders. Record collection actions and custody. If active theft is occurring, containment may take priority over complete collection; document the decision.
- Contain: the incident commander authorizes isolation of the affected service or approved emergency access restrictions. Block suspected malicious access and unnecessary ingress and egress. Preserve controlled responder access; identify dependent workflows before disabling service accounts or rotating secrets.
- Eradicate: work with the vendor and responders to identify persistence, remove unauthorized access, remediate affected software, and rebuild systems when integrity cannot be established. Patching alone does not establish that an already compromised host is clean. Use product-specific guidance. [5]
- Recover: validate the supported configuration, access controls, logging, and required integrations in a controlled environment. Restore trusted data, test representative transfers, obtain service-owner approval, and reconnect in stages with increased monitoring.

Ransomware and endpoint compromise

- Detect and triage: correlate user reports with endpoint and email evidence. Examine suspicious attachment execution, process chains, encryption activity, and backup interference. Determine affected hosts and identities rather than assuming the entire enterprise is infected.
- Contain and preserve: authorized responders isolate affected hosts or segments, preserve available endpoint and email evidence, and restrict compromised identities. Confirm that containment has not unnecessarily disabled clean services or responder access.
- Eradicate and recover: identify the entry path and persistence, rebuild affected hosts from trusted sources, rotate affected secrets, and restore from verified clean backups. Test application integrity and security controls before reconnecting systems. Monitor for reinfection.

For both incidents, maintain a decision log, assess potential data exposure with legal counsel, communicate service impacts, and complete a lessons-learned review. Payment is not a recovery control and does not guarantee restoration; establish an executive and legal decision process and encourage prompt law-enforcement reporting. [6]

Response authority and team readiness

The proposed model assigns responsibilities, not assumed new headcount. Leadership should name primary and backup owners and use an MDR or incident-response partner where internal coverage is insufficient. Validate provider response authority, escalation terms, access, and evidence-handling responsibilities before activation.

Role	Decision or responsibility
Incident commander	Own incident severity, response priorities, containment authorization, decision log, and escalation to leadership. Designate a backup.
Technical responders	Collect evidence, investigate scope, execute approved containment and recovery, and document validation results.
Legal and compliance liaison	Assess applicable reporting duties, preserve legal coordination, and review external notifications and payment-related decisions.
Service owner and executive sponsor	Approve business recovery priorities, resource commitments, outage tradeoffs, and acceptance of remaining risk.
MDR or response provider	Triage and investigate within contracted scope; execute only preauthorized actions; escalate decisions outside that authority.

Proposed escalation sequence

User report or monitoring alert → technical triage and incident record → incident commander severity decision → coordinated technical, legal, and service-owner response → validated restoration → lessons learned and tracked corrective actions.

Confirmed active exfiltration, spreading encryption, privileged-account compromise, or loss of a critical service should trigger urgent commander notification. An on-call roster must define acknowledgement expectations and a fallback route when the primary owner cannot be reached. Pilot response targets in exercises before committing to operational service levels.

Communication and training

Use an approved incident channel and an alternate channel if normal communications may be compromised. Brief executives on verified scope, business impact, decisions needed, and the next update time. Separate confirmed findings from hypotheses. Route external statements through approved communications and legal owners.

Train technical staff on assigned playbooks, evidence handling, and handoffs. Begin with a tabletop exercise and follow with a controlled technical drill. Review staff readiness through role-specific scenarios and repeat exercises when procedures change. Provide staff and students with a simple reporting route and practical phishing awareness guidance.

Implementation roadmap and evaluation

This proposed six-month sequence is dependency-based. Dates are planning windows, not delivery commitments. Procurement, staffing, system discovery, and service-owner availability must be validated. Urgent incident containment or vendor remediation should not wait for the roadmap.

Window	Deliverable and proposed owner	Completion evidence
Days 1–30	Executive sponsor names response owners and backups; IT inventories critical services; legal assesses record scope; responders test backup restoration.	Approved roster, initial inventory, legal assessment questions, and documented restore test.
Days 31–60	IT pilots monitoring and endpoint coverage; sponsor evaluates MDR; Registrar maps release workflow; owners draft patch and AI-use policies.	Coverage gaps recorded; provider scope defined; workflow tested on sample requests; policies reviewed.
Days 61–90	IT expands approved logging and EDR coverage; response lead runs first tabletop; Registrar pilots validated automation.	Alert and escalation tests; exercise findings; pilot error rate and processing-time baseline.
Days 91–120	Network owners test segmentation and dependencies; service owners validate recovery runbooks; Registrar expands automation after pilot review.	Allowed and blocked flow tests; recovery signoffs; migration reconciliation and exception log.
Days 121–180	IT reviews patch and asset coverage; response lead conducts a technical drill; executives review residual risks and funding.	Drill results; remediation backlog; coverage report; approved risk decisions.

Success measures

- Time to contain: measure from the first recorded detection of a confirmed incident to verified containment of its known scope. Record both timestamps and the verification evidence. Report severity, sample size, median, and outliers; track exercises separately from production incidents.
- Coverage and remediation: report the percentage of in-scope assets sending required logs, endpoint protection coverage, and vulnerabilities remediated within approved targets. Include denominators, exclusions, and overdue exceptions.
- Recovery and readiness: measure achieved restore time and recoverable data age against approved recovery objectives. Track drill completion, staff readiness gaps, and corrective-action closure.
- Registrar workflow: compare request processing time, backlog age, and sampled authorization errors before and after the pilot. Improvement remains a hypothesis until measured.

Limitations and references

Decisions requiring validation

The scenario does not provide forensic evidence, identity architecture, asset inventories, backup status, contracts, costs, or a complete control inventory. An omitted control is not automatically an absent control. Actor attribution, enterprise-wide spread, exact data exposure, and regulatory notification requirements cannot be confirmed from these summaries.

The roadmap assumes leadership sponsorship and access to implementation support. Product compatibility, maintenance windows, integration dependencies, and ongoing staffing will determine the final scope. Proposed security controls reduce likelihood or impact; they do not guarantee prevention, containment, uptime, or compliance.

Source scenario and original analysis

Western Governors University. D832 Case Study 4: Sandhaven University (SU), RSN1 Tasks 1, 2, 3. Supplied fictional scenario. Scenario text and assignment instructions are not reproduced in this portfolio report.

Summersill, James. D832 Task 1, Task 2, and Task 3 submissions, September 2026. This portfolio edition consolidates the risk, response, and program recommendations and revises unsupported assumptions. Check course-material sharing requirements before public distribution.

Public references

[1] NIST. (2025). SP 800-61 Rev. 3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile. https://csrc.nist.gov/pubs/sp/800/61/r3/final

[2] U.S. Departments of Education and Health and Human Services. (2019). Joint Guidance on the Application of FERPA and HIPAA to Student Health Records. https://www.hhs.gov/hipaa/for-professionals/special-topics/ferpa-hipaa/index.html

[3] U.S. Department of Education. FERPA Exceptions Summary. https://studentprivacy.ed.gov/sites/default/files/resource_document/file/FERPA%20Exceptions_HANDOUT_portrait_0.pdf

[4] NIST. (2012). SP 800-30 Rev. 1, Guide for Conducting Risk Assessments. https://csrc.nist.gov/pubs/sp/800/30/r1/final

[5] CISA and FBI. AA23-158A, CL0P Ransomware Gang Exploits CVE-2023-34362 MOVEit Vulnerability. Public advisory provides general technical context, not attribution for this fictional incident. https://content.govdelivery.com/accounts/USDHSCISA/bulletins/35ecb08

[6] FBI. Ransomware. https://www.fbi.gov/how-we-can-help-you/common-frauds-and-scams/ransomware